



IPSEC REGULATORY AUDIT & CRYPTOGRAPHIC HEALTH

IPsec VPN Security Assessment & Framework Audit

Comprehensive evaluation against NIST SP 800-77 Rev. 1, RFC 8221, and NSA CNSA 2.0 cryptographic mandates

100
GRADE A • COMPLIANT

CONDITIONAL COMPLIANCE • ATTENTION REQUIRED

The IPsec deployment scored 100.0 out of 100 (GRADE A : COMPLIANT), indicating robust transport confidentiality via AES-256-GCM encryption. However, critical gaps in Child SA forward secrecy and static shared key authentication require remediation under NIST SP 800-77 Rev 1.

Section 1: Scope & Regulatory Framework

Definition of audit benchmarks (NIST SP 800-77 Rev. 1, RFC 8221, NSA CNSA 2.0)

AUDIT SCOPE & TARGET GATEWAYS

Single Link Forensic Scope: Link 2: Tactical Edge <-> Command HQ
(10.0.10.5 (Tactical Edge) <-> 172.28.0.2 (HQ Gateway))

ASSESSMENT TIMEFRAME

Live Telemetry Window: +0.0s
to +15.0s (15.0s)

REGULATORY BENCHMARK	TITLE & JURISDICTION	MANDATED CRYPTOGRAPHIC REQUIREMENTS	AUDIT COMPLIANCE VERDICT
	Guide to IPsec VPNs		CRITICAL NON-COMPLIANCE
	ESP and AH Cryptographic Requirements		NON-COMPLIANT
	Commercial National Security Algorithm Suite		PARTIAL ALIGNMENT

Section 2: Cryptographic Health Audit

Granular evaluation of symmetric ciphers (AES-GCM vs. CBC/3DES) and hashing integrity (SHA-256 vs. SHA-1/MD5)

SYMMETRIC ENCRYPTION CIPHER

APPROVED

3DES-CBC (168-bit Effective Key)

Operating Mode: CBC Mode (Cipher Block Chaining)
Integrity Tag: Separate HMAC Required (Truncated 96-bit)
Key Length: 168 bits (64-bit Block Size)

3DES-CBC utilizes a 64-bit block size banned by NIST SP 800-131A. Vulnerable to practical birthday collision attacks (Sweet32 - CVE-2016-2183) after 2^32 blocks.

HASHING & MESSAGE INTEGRITY

APPROVED

HMAC-SHA-1 (Deprecated)

Digest Size: 160 bits (Truncated to 96 bits)
Collision Resistance: Verified (FIPS 180-4 Compliant)
Deprecated Primitives: MD5 / SHA-1 Not Detected

SHA-1 has demonstrated practical chosen-prefix collisions (SHAttered attack). Officially deprecated by NIST for all federal cryptographic uses.



KEY MANAGEMENT, PROTOCOL & STATE INTEGRITY

Key Exchange & Protocol State Integrity

Diffie-Hellman modulus size verification, post-quantum posture, sequence rollover safeguards, and anti-replay integrity

Section 3: Key Management & Exchange Audit

Verification of Diffie-Hellman modulus size, post-quantum posture, and PFS rekey enforcement

DIFFIE-HELLMAN MODULUS STRENGTH APPROVED Group 2 (1024-bit MODP) 1024-bit (~80-bit security strength) 1024-bit Diffie-Hellman Group 2 is vulnerable to precomputation attacks (Logjam). Deprecated by NIST SP 800-131A in 2013.	PERFECT FORWARD SECRECY (PFS) REKEY CRITICAL NON-COMPLIANCE Active on Group 2 (Logjam Vulnerable) IKE SA: Active (Group 2) -15 pts While an ephemeral exchange occurs, the 1024-bit group modulus provides negligible protection against nation-state adversaries.
POST-QUANTUM CRYPTOGRAPHIC POSTURE TRANSITION MANDATED CRITICAL LEGACY Target: Hybrid ML-KEM-768 (Kyber) + ECP-256 Emergency migration to AES-256-GCM and DH Group 19 required prior to any PQC evaluation.	SA ROTATION LIFETIMES & LIMITS ALIGNED 3600 seconds (1 Hour) 1,000 MB (1 GB Transfer Threshold) Strict rekey intervals constrain cryptanalytic exposure window under high packet volumes, adhering to RFC 7296 recommendations.

Section 4: Protocol & State Integrity

Anti-replay window sizing, sequence rollover safeguards, and IKE mode security (e.g., IKEv1 Aggressive Mode detection)

ANTI-REPLAY WINDOW SIZING ACTIVE & VERIFIED 64-bit sliding window (RFC 4303) Kernel IPsec state maintains strict packet sequence bitmap. Zero replay packet injection attempts observed.	SEQUENCE ROLLOVER SAFEGUARDS HARDENED 64-bit Extended Sequence Numbers (ESN) Protects against 2^{32} sequence cycling attacks under 100Gbps+ multi-core line-rate traffic. Safe for >500 years continuous transfer.	IKE MODE SECURITY & DOWNGRADE PROTECTED IKEv1 (Deprecated RFC 9395) IKEv1 Aggressive Mode NOT detected. Unencrypted identity hashing is prevented, neutralizing offline dictionary cracking.
--	---	--



SIDE-CHANNEL AUDIT & METADATA VULNERABILITY REGISTER

Side-Channel & Metadata Vulnerability Audit

Traffic Flow Confidentiality (TFC) leakage, packet shape predictability, and side-channel exposure register

Section 5: Side-Channel & Metadata Vulnerability Audit

Leakage score based on packet shape predictability, burstiness, and missing Traffic Flow Confidentiality (TFC) padding

SIDE-CHANNEL
LEAKAGE SCORE

42

HIGH RISK

Quantifies side-channel intelligence exposure based on unpadded packet length distributions and transmission cadences.

PACKET SHAPE
PREDICTABILITY

HIGH PREDICTABILITY

Packet length clustering and inter-arrival timing evaluated across telemetry windows.

BURSTINESS & IAT
TIMING

MODERATE LEAKAGE

Inter-arrival timing demonstrates regular cadence across tunnel flows.

TFC PADDING AUDIT

RECOMMENDED (-3 pts)

Activate Traffic Flow Confidentiality (TFC) padding per RFC 4303 §2.7 to mask packet size signatures.

METADATA LEAKAGE ASSESSMENT & TFC DEFENSE STRATEGY

While payload encryption via AES-256-GCM is mathematically unbreakable under current cryptanalytic standards, passive adversaries monitoring the wire can extract valuable behavioral intelligence without decrypting the payload. Packet arrival intervals, burst durations, and frame sizes correlate strongly with user activity, application types, and data transfer volumes. Enabling strongSwan Traffic Flow Confidentiality (`'esp_proposals = aes256gcm16-ecp256!'`, `'tfc = yes'`) and injecting dummy padding packets eliminates side-channel signatures.



Comprehensive Threat Matrix & Remediation Roadmap

Comprehensive Threat Matrix & Posture Projection

Detailed register of discovered vulnerabilities, CVSS base/environmental scores, and post-remediation posture projection

Section 6: Comprehensive Threat & Vulnerability Matrix

Detailed register of discovered vulnerabilities, CVSS base/environmental scores, and audit remediation mandates

VULN ID	VULNERABILITY & THREAT VECTOR	CVSS v3.1 BASE / ENV	SEVERITY	REMEDIATION MANDATE
AV-VULN-L2-001	Critical Weak Cipher: 3DES-CBC (Sweet32 Vulnerable)	Base: 8.1 Env: 7.8	CRITICAL	
AV-VULN-L2-002	Insecure Diffie-Hellman Group 2 (1024-bit MODP)	Base: 8.2 Env: 8	CRITICAL	
AV-VULN-L2-003	Deprecated SHA-1 Integrity/PRF (SHattered Vulnerable)	Base: 7.4 Env: 7	HIGH	
AV-VULN-L2-004	Deprecated IKEv1 Protocol (RFC 9395)	Base: 7.1 Env: 6.8	HIGH	

2
CRITICAL

2
HIGH

0
MEDIUM

0
LOW

PROJECTED POST-REMEDIATION POSTURE

CURRENT SCORE	PROJECTED GAIN	PROJECTED SCORE	PROJECTED GRADE
24 / 100	+70 pts	94 / 100	GRADE A+ - FULLY HARDENED

Applying the prioritized cryptographic directives immediately eliminates vulnerability penalty points, elevating the evaluated IPsec deployment to complete NIST SP 800-77 Rev. 1 compliance.

OFFICIAL COMPLIANCE ACCREDITATION

This security evaluation was conducted according to the NIST SP 800-77 Rev. 1 and RFC 8221 security assessment methodologies. Cryptographic controls have been validated via deep deterministic state analysis.

ACCREDITATION STATUS

Classification: RESTRICTED
Framework: NIST SP 800-77 Rev. 1
Integrity: Cryptographically Signed